

CYBERSECURITY DEFENSIVE HOME LABORATORY

Design, Implementation & Essential Eight Alignment Technical Report

Author: Nathan | University Student (IT/Cybersecurity) | Perth, Western Australia

Prepared for: Australian Defence Force (ADF) RAAF Cyber Warfare Officer Application Portfolio

Associated Activity: AAFC 721 Squadron (WA) Cadet Application & Cybersecurity Skills Development

Date: 9 July 2026

EXECUTIVE SUMMARY

This technical report documents the complete design, provisioning, and initial implementation of an isolated multi-virtual-machine cybersecurity home laboratory environment. The laboratory has been purpose-built to replicate a protected enterprise-grade network architecture consistent with Australian Signals Directorate (ASD) Essential Eight mitigation strategies and the broader Information Security Manual (ISM) framework. The primary objective is to establish a safe, repeatable, and realistic environment for developing practical defensive cybersecurity capabilities in direct support of an application for the Royal Australian Air Force (RAAF) Cyber Warfare Officer role.

The lab architecture implements defence-in-depth through network segmentation, centralized identity management via Active Directory, controlled attack surfaces using intentionally vulnerable targets, and a dedicated attacker platform (Kali Linux) for authorised penetration testing and red-team exercises. All configurations have been explicitly mapped to the eight Essential Eight controls, enabling direct demonstration of practical implementation skills for ADF selection processes and future operational relevance.

Key deliverables include a fully functional segmented network environment, comprehensive configuration documentation, validation evidence of Essential Eight controls, and a clear mapping of acquired skills to the responsibilities of a Cyber Warfare Officer. This work forms a core component of a competitive, evidence-based portfolio demonstrating proactive engagement with Australian cyber security frameworks and a genuine commitment to the ADF cyber capability mission.

1. INTRODUCTION AND OBJECTIVES

The Australian Defence Force (ADF) and specifically the Royal Australian Air Force (RAAF) are expanding their cyberspace warfare capabilities to protect critical networks, data, and information systems. The Cyber Warfare Officer role requires personnel who can lead technical teams in defensive operations, implement robust security controls, conduct threat hunting and incident response, and maintain systems aligned with national frameworks such as the ASD Essential Eight and ISM. Practical, hands-on experience with realistic environments is therefore essential for both selection success and future operational effectiveness.

This home laboratory project addresses that requirement by creating a self-contained, air-gapped (from production) environment that mirrors key elements of a defended network. The laboratory enables safe execution of offensive security techniques (penetration testing, exploitation, post-exploitation) followed by immediate defensive hardening, detection validation, and forensic analysis. All work is conducted ethically within isolated virtual machines with full snapshot and rollback capability.

1.1 Specific Objectives

- Design and implement a segmented network architecture using a stateful firewall/router as the security boundary.
- Deploy and harden a Windows Server Active Directory domain with Group Policy enforcement of least-privilege principles.
- Provision intentionally vulnerable target systems (Metasploitable) to enable realistic attack simulation and subsequent remediation.
- Establish a dedicated attacker platform (Kali Linux) with full tooling for authorised red-team activities.
- Map every major configuration and control explicitly to the ASD Essential Eight strategies with validation evidence.

- Produce professional-grade documentation suitable for inclusion in an ADF Cyber Warfare Officer application portfolio.
- Develop transferable skills in network defence, identity management, vulnerability management, and security monitoring.

2. ARCHITECTURE DESIGN

The laboratory employs a classic defence-in-depth network segmentation model with four distinct security zones separated by the pfSense firewall. This design directly emulates the tiered network architectures commonly found in government and defence environments, where different trust levels and data sensitivity classifications require strict traffic control and monitoring.

2.1 Network Segmentation Model

VM Name	Role / Zone	Operating System	vCPU / RAM	Primary IP
pfSense-FW	Firewall / Router (All Zones)	pfSense 2.7.x (FreeBSD)	2 / 2 GB	Various (WAN, LAN 192.168.10.1/24, DMZ 192.168.20.1/24, MGMT 192.168.30.1/24)
DC01	Domain Controller (Internal Protected)	Windows Server 2022	4 / 8 GB	192.168.10.10/24
CLIENT01	Domain-Joined Workstation (Internal)	Windows 10/11 Pro	2 / 4 GB	192.168.10.50/24 (DHCP)
METASPL01	Vulnerable Target (DMZ)	Metasploitable 3 / Linux	2 / 4 GB	192.168.20.100/24
KALI-ATTACK	Attacker Platform (MGMT / Attacker)	Kali Linux 2025.x	4 / 8 GB	192.168.30.50/24 (Static)

Table 1: Virtual Machine Inventory and Network Zone Assignment

The pfSense firewall acts as the sole gateway between zones. Firewall rules are deliberately restrictive: the DMZ (where Metasploitable resides) has no direct inbound access from the internet simulation and limited outbound to the internal LAN. The management/attacker subnet (Kali) is permitted to initiate connections to both DMZ and internal zones for testing purposes, while return traffic is controlled via stateful inspection. This setup allows safe execution of attacks from Kali while preventing lateral movement from a compromised DMZ host into the protected domain.

3. DETAILED IMPLEMENTATION STEPS

The laboratory was provisioned using VirtualBox 7.x on a capable host system. All virtual machines were created with appropriate resource allocations and network adapter configurations matching the zone model. Snapshots were taken at key milestones to enable rapid rollback during testing and configuration changes.

3.1 pfSense Firewall and Router Configuration

Installation: Downloaded the latest pfSense 2.7.x ISO (amd64). Created a new VM with 2 vCPU, 2 GB RAM, and four network adapters assigned as follows: Adapter 1 = NAT (simulated WAN), Adapter 2 = Internal Network "LAN", Adapter 3 = Internal Network "DMZ", Adapter 4 = Internal Network "MGMT". Booted the ISO and completed the console-based installer, assigning interfaces in the order em0=WAN, em1=LAN, em2=DMZ, em3=MGMT.

Initial Setup: After reboot, accessed the web configurator at https://192.168.1.1 (default LAN IP). Changed the LAN IP to 192.168.10.1/24, enabled the DHCP server on LAN (range 192.168.10.100-200), and configured WAN as DHCP client (or static for lab consistency). Created VLANs or additional interfaces for DMZ (192.168.20.1/24) and MGMT (192.168.30.1/24).

Firewall Rules (Key Examples): LAN to any: allow established/related only. DMZ to LAN: deny all (no direct access). MGMT (Kali) to DMZ: allow all for testing. MGMT to LAN: allow specific ports (RDP 3389, SMB 445, WinRM 5985) with source restriction. WAN to LAN/DMZ: deny all. Outbound NAT configured for all internal subnets. Package manager used to install additional tools (e.g., ntopng, Suricata IDS) for future monitoring expansion.

3.2 Windows Server Active Directory Domain Controller

Installation: Created VM with Windows Server 2022 Evaluation ISO. Configured static IP 192.168.10.10/24, gateway 192.168.10.1, DNS 127.0.0.1 (self). Renamed server to DC01. Installed Active Directory Domain Services and DNS Server roles via Server Manager. Promoted to domain controller for a new forest (e.g., lab.local) using PowerShell or the graphical wizard, creating a strong Directory Services Restore Mode (DSRM) password.

Group Policy Hardening (Essential Eight Alignment): Created a new GPO linked to the domain root and OU structure. Key settings applied: Password Policy (complexity, length 14+, history 24, max age 90 days); Account Lockout (threshold 5, duration 15 min); User Rights Assignment (restrict local logon to specific groups); Windows Firewall enabled with logging; AppLocker rules configured in audit mode initially then enforced for standard users (allow only signed executables and specific paths). Windows Update configured for automatic download and scheduled install. PowerShell execution policy set to RemoteSigned with logging enabled.

3.3 Vulnerable Targets and Attacker Platform

Metasploitable Deployment: Downloaded and imported the Metasploitable 3 Vagrant box or pre-built VM image. Placed in DMZ subnet (192.168.20.100). Verified vulnerable services (vsftpd backdoor, Samba, Apache with known exploits, SSH with weak credentials). This machine serves as the primary target for initial exploitation exercises.

Kali Linux Attacker: Installed latest Kali Linux rolling release. Configured static IP in MGMT subnet. Updated tools (apt update && apt full-upgrade). Installed additional packages as needed (bloodhound, crackmapexec, etc.). Verified connectivity to both DMZ and LAN targets through the firewall rules. This platform is used exclusively for authorised offensive security activities against the lab targets.

4. ESSENTIAL EIGHT CONTROLS – IMPLEMENTATION & VALIDATION

A core design goal was to ensure every major control implemented in the laboratory could be directly mapped to one or more of the ASD Essential Eight mitigation strategies. The following table summarises the mapping, specific implementation actions, and validation methods used.

Essential Eight Strategy	Lab Implementation	Validation Method
1. Application Control	AppLocker deployed via GPO on DC01 and CLIENT01. Allowed paths and publishers only for standard users. pfSense application layer filtering considered for future.	Attempted execution of unsigned/unauthorised binaries from user context – blocked. Audit logs reviewed.
2. Patch Applications	Windows Update GPO configured for automatic download + scheduled install. pfSense packages kept current via manual update process. Metasploitable left deliberately unpatched for testing.	WSUS or manual patch verification; re-testing of known exploits post-patch where applicable.
3. Patch Operating Systems	Windows Server and client VMs configured with automatic Windows Update. pfSense security updates applied via console/pkg.	System update history reviewed; vulnerability scanners run before/after patching cycles.
4. Restrict Administrative Privileges	Tiered admin accounts created (Domain Admins, Server Admins, Workstation Admins). GPO User Rights Assignment restricts local logon and privilege use. No daily-use accounts have admin rights.	Attempted lateral movement or privilege escalation from standard user context – blocked or logged.
5. Configure Microsoft Office Macros	Office not installed on lab VMs by default. When added, Group Policy disables macros from internet sources and requires signed macros.	Test macro-enabled documents from untrusted sources – execution prevented.
6. User Application Hardening	Browser hardening (Edge/Chrome) via GPO: disable unnecessary plugins, enable safe browsing, block Java/Flash where present. PowerShell constrained language mode for standard users.	Attempted browser-based exploits or script execution – mitigated or detected.
7. Multi-factor Authentication	Not yet implemented in current lab build (future work). Planned integration with Azure AD / conditional access simulation or on-prem MFA server.	N/A – planned control.
8. Regular Backups	VirtualBox snapshot strategy implemented (daily/weekly manual + before major changes). Export of VM configs and pfSense backups to external storage planned.	Successful restore from snapshot after deliberate misconfiguration or ransomware simulation.

Table 2: ASD Essential Eight Controls – Lab Implementation and Validation Summary

5. TESTING, VALIDATION AND SECURITY ASSESSMENT

Initial validation of the lab environment was performed through a structured series of authorised penetration testing exercises from the Kali platform. Nmap service and vulnerability scans were conducted against the Metasploitable target and, where authorised, the Windows domain-joined assets. Key findings included the expected presence of the vsftpd backdoor, weak SMB authentication on Metasploitable, and several Windows misconfigurations that were subsequently remediated through GPO changes.

Post-remediation re-testing confirmed that previously successful exploitation paths were blocked or significantly mitigated. For example, after enforcing AppLocker and removing unnecessary local admin rights, several post-exploitation techniques that previously succeeded were prevented. Firewall rule reviews and packet captures verified that lateral movement attempts from the DMZ were contained as designed.

6. LESSONS LEARNED AND SKILLS DEVELOPED

Building and operating this laboratory yielded several practical insights directly relevant to ADF cyber operations:

- **Segmentation is foundational:** Properly designed firewall rules and network zones dramatically reduce the blast radius of a compromise. This principle is directly applicable to protecting ADF networks and segmented operational environments.
- **Identity is the new perimeter:** Active Directory hardening (least privilege, GPO enforcement, privileged access management) proved more impactful than many network-layer controls alone. This aligns with modern zero-trust thinking and ISM guidance.
- **Documentation enables repeatability and audit:** Maintaining detailed configuration records, change logs, and validation evidence is essential for both personal learning and demonstrating capability to selection panels or future operational teams.
- **Red team / blue team iteration accelerates learning:** The ability to attack, observe detection opportunities, remediate, and immediately re-test creates a rapid feedback loop that is difficult to achieve in production environments.
- **Essential Eight is practical, not theoretical:** Implementing each of the eight controls in a real (albeit small) environment revealed interdependencies and operational considerations that purely theoretical study cannot convey.

7. ALIGNMENT WITH RAAF CYBER WARFARE OFFICER ROLE

The skills and artefacts produced through this project map directly to the core responsibilities of a Cyber Warfare Officer: protecting networks, data, and information systems through technical leadership, defensive operations, and the implementation of robust security controls. The laboratory provides a tangible demonstration of the ability to design, build, test, and document secure environments — capabilities that are immediately relevant to both the selection process and subsequent Initial Employment Training and operational postings.

Furthermore, the project reinforces the importance of aligning technical implementations with national frameworks (Essential Eight, ISM), a key expectation for personnel operating in the ADF cyber domain. The documentation produced is suitable for direct inclusion in an application portfolio and can serve as discussion points during interviews or assessment centre activities.

8. CONCLUSION AND FUTURE WORK

The cybersecurity home laboratory is now operational and provides a robust platform for ongoing skills development. Planned future enhancements include: full implementation of multi-factor authentication simulation; deployment of a centralised SIEM (Wazuh or Elastic) for log aggregation and detection engineering; expansion of the lab to include additional operating systems and cloud-hybrid scenarios; and integration of digital forensics workflows using tools such as Autopsy and Volatility on acquired images from compromised VMs.

This project represents a significant step in building a credible, evidence-based portfolio for ADF Cyber Warfare Officer selection. It demonstrates not only technical proficiency but also the structured, documented approach to cybersecurity that is essential for success in both the application process and a future career protecting Australia's defence networks and systems.

References & Further Reading

Australian Signals Directorate. (n.d.). *Essential Eight*.
<https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/essential-eight>
Australian Signals Directorate. (n.d.). *Information Security Manual (ISM)*. <https://www.cyber.gov.au/ism>
Defence Signals Directorate / Australian Signals Directorate historical publications on mitigation strategies.
VirtualBox Documentation and pfSense Documentation (official project wikis).
Microsoft Security Baselines and Group Policy guidance for Windows Server 2022 and Windows 10/11.